

ÉTUDE DE RECHERCHE / RAPPORT PRINCIPAL

LANCE : mesurer l'apport des LLM

Couverture du benchmark, contexte du pipeline
et protocole de comparaison

Exploration et protocole proposés / 29 septembre 2026

Question. Dans quelles situations un modèle de langage améliore-t-il un audit IoT autorisé, à outils et budgets comparables à une automatisation conditionnelle bien conçue ?

État de la recherche. Trois inspections GPT et une contrelecture croisée ont identifié des limites concrètes. Huit probes synthétiques ont été rejouées localement ; 381 tests logiciels ciblés passent. Aucun résultat de campagne ne démontre encore un gain technique ou humain du modèle.

1 Lecture d'ensemble

Le projet dispose déjà d'un socle de collecte, de contrats de preuve et d'une comparaison D1/A1 bornée. La prochaine étape consiste à rendre les mesures et l'attribution suffisamment fiables pour qu'un résultat positif, négatif ou indéterminé ait un sens. Le tableau 1 résume les trois études.

Axe	Faits établis dans le périmètre inspecté	Question encore ouverte
Benchmark	29 scénarios ; 288 vulnérabilités attendues ; aucun scénario officiel entièrement sain. Défauts locaux de taux de tentative et d'admission de preuves.	Quelles propriétés sont réellement déployées, observées et prouvées ? Quelle fréquence d'erreur en campagne ?
Contexte	Certaines sorties coupées avant archivage ; historique outils renvoyé sans budget d'entrée ; projections parfois sans récupération.	Quel effet sur les décisions, le rappel, la fiabilité et les ressources ?
Apport LLM	Scanner partagé riche en connaissances des simulateurs ; comparaison disponible sur les phases 3-4, inventaire fourni, profil full.	Quel gain marginal du modèle et quel mécanisme le produit ?

Table 1 – Faits de logiciel et de corpus ; aucune colonne ne rapporte une performance de campagne.

Le présent rapport fournit la synthèse et le protocole de décision. Deux rapports spécialisés détaillent les preuves : *Couverture et validité du benchmark* et *Gestion du contexte du pipeline*. Les notes d'inspection et les références de code restent dans les mêmes dossiers.

Preuve / limite. Révision inspectée : 45c8dab892ecb4e5f513813387090e0cded1b85d, avec une réorganisation documentaire locale préexistante. Les changements de cette livraison portent sur les documents, les figures et les reproductions. Les corrections du logiciel décrites ci-dessous restent proposées.

2 Ce que compare aujourd'hui D1/A1

2.1 Un ajout au socle déterministe

Les deux politiques utilisent un inventaire public commun et le même scanner initial. D1 produit les findings par règles, puis suit des plans de vérification avec une reprise transitoire et un complément HTTP bornés. A1 ajoute des micro-agents en phase 3 et des décisions modèle en phase 4. La figure 1 représente ce périmètre implémenté ; elle ne décrit pas encore un audit complet avec reconnaissance, intrusion et rédaction comparées.



Figure 1 – Comparaison actuellement disponible : effet marginal de la politique LLM au-dessus du scanner partagé, dans les phases 3–4. Le validateur commun assure une symétrie interne ; sa sémantique doit aussi être calibrée indépendamment.

Un succès absolu d’A1 ne prouve pas que le modèle a causé ce succès. Le scanner contient déjà des endpoints, identités et séquences propres aux simulateurs. La provenance d’une action est utile pour suivre une trajectoire, mais une ablation contrôlée est nécessaire pour attribuer un gain au modèle.

Preuve / limite. Chemins inspectés : `src/agent/audit_experiment.py`, `src/agent/phases/analysis/run.py`, `src/agent/scanner.py`, `src/agent/phases/verification/rules.py`. La branche de mémo phase 3 compact local décrite dans l’étude contexte est distincte : D1/A1 impose le profil full.

2.2 Une référence classique à renforcer sur développement

D1 est déjà conditionnel, mais borné. Une victoire d’A1 sur une lacune connue et réparable de D1 n’établirait pas la nécessité d’un LLM. Avant le gel, revoir l’extraction des paramètres observables, les branchements, l’état partagé, les identités découvertes, les contrôles négatifs et les critères d’arrêt. Les workflows conditionnels de Nuclei illustrent des possibilités classiques sans modèle [2] ; ils ne garantissent pas une couverture IoT universelle.

Établir une matrice d’origine des connaissances pour chaque famille : information publique fournie, observation obtenue, règle scanner, prompt, connaissance du modèle ou oracle privé. Les deux politiques ont accès aux mêmes informations opérationnelles autorisées. Le test réservé ne fournit aucune réponse via les noms, rôles ou descriptions.

3 Fiabiliser les dimensions de couverture

3.1 Corpus, tentative et preuve ont des dénominateurs différents

Le corpus officiel comprend 19 scénarios de développement et 10 de test, respectivement 252 et 36 GT positives. Les 288 GT, 249 instances de services et 67 chemins déclarés ne constituent pas des mécanismes indépendants. Les scénarios S1–S13 regroupent 229 GT ; le test est surtout HTTP/SSH. Les variantes historiques S1h/S4h ne s’ajoutent pas aux 29 scénarios officiels.

Une tentative sur tous les candidats retenus ne signifie pas que tous les actifs, services ou failles ont été explorés. Conserver des populations distinctes : actifs attendus lorsque connus, services observés, GT proposées, candidats retenus, candidats effectivement tentés, preuves admises et GT confirmées. Le score d’intrusion reste séparé du F1 d’audit.

3.2 Contre-exemples locaux et portée exacte

Priorité proposée : séparer attribution, tentative et verdict ; définir les contrôles par cible, service, identité, action et observation attendue ; calibrer les oracles sur preuves positives et contre-exemples annotés indépendamment. Un nonce réfléchi dans une réponse ne prouve pas une exécution. L’oracle doit distinguer réflexion, exemple statique et effet attendu, avec contrôle différentiel ou attestation de cible.

Contre-exemple	Observation reproduite	Portée du constat
Tentatives ambiguës	Un candidat, deux TIMEOUT marqués non tentés : taux de tentative 1,0.	Défaut du diagnostic d'entonnoir ; fréquence en campagne inconnue.
Contrôle S18	Une exposition avec jeton surprivilégié partage IP/type avec un contrôle exigeant le refus d'un autre jeton limité.	Contrôle déclaré violé avec le mauvais jeton ; aucune pénalité additionnelle directe démontrée sur le F1 principal.
Oracle OTA	Une trace déclarant une signature valide est admise comme EXPLOITED, niveau 2.	Admission d'une observation insuffisante ; aucune signature cryptographique ni état serveur vérifié.
Oracle exécution	Une réponse d'aide contenant <code>uid=1000(user)</code> est admise au niveau 3.	Un exemple textuel est pris pour preuve ; le crédit dans le score complet n'est pas reproduit.

Table 2 – Défauts et limites identifiés par inspection ou probes synthétiques, sans extrapolation à un taux d'erreur réel.

Les propriétés du laboratoire doivent être vérifiées avant l'essai. Un précontrôle perturbateur peut modifier l'état : réinitialiser ensuite, puis réaliser un contrôle final non perturbateur. Le hash d'un constat assure sa traçabilité, pas la validité de son contenu. Pour les pivots, la provenance causale d'une transition réseau reste absente : plusieurs connexions directes ne démontrent pas un chemin multi-hop.

4 Contexte : préserver les informations avant d'optimiser

Le rapport de phase 6 utilise déjà des fiches indépendantes et un assemblage déterministe. Le reprendre comme un gros contexte global ignorerait cette amélioration. Les problèmes inspectés concernent plusieurs frontières :

- **Capture.** Certains outils YAML filtrent et tronquent stdout avant que le journal ne reçoive le résultat. Une référence au journal ne récupère pas une donnée qui n'y a jamais été conservée.
- **Conversation.** La boucle outils renvoie l'historique intégral, sans admission explicite selon un budget d'entrée et une réserve de sortie. Les plafonds de tours ne garantissent pas une requête compatible avec la fenêtre.
- **Projection.** Le contexte compact peut perdre une preuve au milieu ou des services entiers ; certains chemins exposent uniquement la sauvegarde et ne peuvent pas relire les références affichées.
- **Transmission.** Des coupes de preuves et des sélections d'alternatives par IP retirent des éléments sans signaler systématiquement leur omission.

Les cinq probes synthétiques établissent des transformations, pas leur effet sur un score : preuve centrale perdue avec zéro entrée omise, 20 services réduits à 6, observations tronquées, blocs de tailles [2, 2, 2, 14] et mémos incomplets non détectés. Une sortie interrompue par `finish_reason=length` ne prouve pas à elle seule une saturation de l'entrée.

La proposition est de conserver un brut attribué et versionné, puis construire des vues déterministes portant leurs omissions et références. Fournir des lectures ciblées, bornées et sans nouvelle sonde réseau aux politiques qui en ont besoin. Comparer d'abord cette solution à une meilleure projection simple : le retrieval peut augmenter coût et délai ou manquer la bonne preuve. Les recommandations sur le chargement à la demande motivent ce test [3], et la sensibilité à la position documentée dans d'autres tâches motive des permutations [4] ; elles ne valident aucun modèle actuel de LANCE.

5 Expériences proposées : isoler les contributions

5.1 Politiques et mécanismes

Politique	Décisions	Rôle expérimental
D0	Procédure fixe.	Référence simple secondaire.
D1	Règles, état partagé, branchements et reprises bornées.	Référence principale sans LLM ; premier incrément disponible.
A0	Plan initial LLM puis figé, branches prévues autorisées.	Isoler l'effet de nouvelles décisions après retour ; à implémenter.
A1	Politique LLM révisée selon les observations.	Traitement étudié ; incrément borné disponible.
D1-R	Même audit D1, rédaction LLM après clôture.	Étudier restitution et effort humain ; proposé.

Table 3 – Les politiques proposées dépassent la comparaison logicielle actuellement disponible ; leur présence dans ce tableau n'atteste pas leur implémentation.

Question	Contraste	Conclusion permise
Interprétation	Règles / LLM sur dossiers identiques, collecte désactivée.	Qualité d'interprétation et fidélité des preuves.
Audit borné	D1 / A1, mêmes inventaire, outils, état initial et plafonds.	Gain marginal au-dessus du socle partagé.
Adaptation	A0 / A1 après un obstacle externe reproductible.	Utilité de nouvelles décisions après retour.
Gestion du contexte	Même politique/modèle, stratégie de représentation seule modifiée.	Effet de la représentation et de ses coûts.
Restitution	D1 / D1-R, mêmes faits, étude aveugle d'auditeurs.	Temps de compréhension/correction et qualité des décisions humaines.

Table 4 – Contrastes distincts pour éviter de créditer au modèle les effets de meilleurs outils, d'un index ou d'un budget différent.

D1-R doit conserver exactement les scores techniques de D1. Un changement signalerait que la mesure technique dépend de la prose. Les temps humains nécessitent une étude dédiée ; ils ne se déduisent pas des tokens ou de l'absence d'intervention. La comparaison de plusieurs modèles répond à une question de choix de modèle, sans remplacer D1/A1.

5.2 Variations et ablations

Séparer variation du format brut et recomposition des dépendances. Fournir aussi une strate où les mêmes informations sont normalisées pour les deux politiques. Un avantage qui disparaît après normalisation peut relever du parseur ; pour étudier l'adaptation, introduire des informations ou obstacles qui nécessitent une révision d'action. Les perturbations sont externes, reproductibles et horodatées ; une panne accidentelle n'est pas requalifiée après coup.

Pour le contexte, comparer une projection actuelle, une meilleure projection déterministe et des vues avec lectures ciblées. Garder identiques les capacités de lecture pour isoler la projection ; retirer les lectures dans une ablation distincte. Tester position début/milieu/fin, permutation des services, bruit, contradictions tardives et éléments répartis entre plusieurs services. Mesurer fidélité, attribution, abstention, omissions, lectures, temps et coût.

Compact/full change outils, budgets, obligations et rôle du modèle : ce contraste ne constitue pas une ablation propre du contexte. Une trace figée hors ligne ne reproduit pas les effets d'actions divergentes sur le réseau.

6 Protocole statistique et ressources

6.1 Unité d'analyse

Garder les deux bras appariés sur la même instance et le même état initial. Réinitialiser avant chaque bras et contrebalancer l'ordre D1/A1 par blocs. Pour la différence principale, une hiérarchie proposée est : moyenne des répétitions dans une variante, moyenne des variantes dans une famille, puis poids égal des familles. Avec f une famille, v une variante et r une répétition, poser, pour le F1 final des confirmations sur les scénarios positifs au budget principal fixé :

$$d_{fvr} = F1(A1_{fvr}) - F1(D1_{fvr}), \quad \Delta = \frac{1}{F} \sum_f \frac{1}{V_f} \sum_v \frac{1}{R_{fv}} \sum_r d_{fvr}.$$

Cette analyse de recherche ne modifie pas les agrégats officiels par scénario et par split. Elle suppose une règle explicite de disponibilité des paires. Les scénarios entièrement sains ont un F1 indéfini ; analyser séparément leurs fausses alertes et violations, sans les inclure dans cette moyenne. Les familles reflètent l'origine technique et les mécanismes partagés ; un label de manifeste n'en prouve pas l'indépendance.

Estimer l'incertitude à 95% par rééchantillonnage apparié des familles en gardant leur structure interne, après validation du schéma de données. Sur peu de familles, rester descriptif : le bootstrap ne crée pas de diversité. Les principes généraux des tests appariés [5] ne donnent pas à eux seuls la puissance du pilote. Dimensionner le test à partir du développement, de la variance et du gain minimal utile. Déclarer un contraste principal et les analyses secondaires avant la lecture du test.

6.2 Échecs, coûts et reproductibilité

La moyenne des paires admissibles est conditionnelle aux survivants. Conserver les essais prévus, échecs, arrêts, budgets dépassés et dépenses connues. Les scores techniques indisponibles restent indisponibles. Ajouter séparément une réussite opérationnelle définie avant test : résultat évaluable et niveau de qualité atteint avant plafond, sur environnement initialement valide.

Fixer des plafonds comparables de durée murale et charge réseau : requêtes, cibles, plages et débits. Un appel Nmap ne représente pas une seule sonde, et un plafond de tokens n'est pas un budget commun avec D1. Séparer coût LLM marginal, calcul/infrastructure, préparation, développement, maintenance et temps humain. Un ratio coût/VP est indéfini si VP vaut zéro ; les dépenses restent visibles. L'étude doit présenter les compromis qualité/coût, plutôt qu'un seul score favorable choisi après observation [1].

Figurer sources et diff local, règles/prompts, snapshot CVE, SDK, outils/OS, inventaire, état initial, perturbations, endpoint sans secret ou empreinte, version résolue du modèle et paramètres effectifs connus ou inconnus. La configuration actuelle ne capture pas entièrement endpoint et defaults fournisseur ; l'égalité d'un nom et du hash source ne suffit pas.

7 Ordre de travail et décisions

La figure 2 indique l'ordre proposé. Le pilote peut apprendre sur les phases 3–4 correctement vérifiables sans attendre une refonte complète ou la preuve de tous les pivots. Ses conclusions restent descriptives.

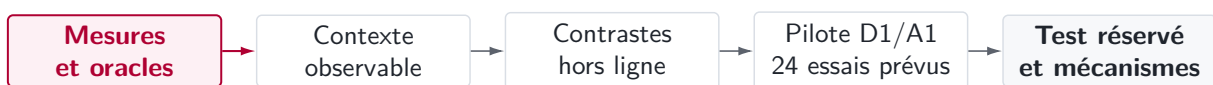


Figure 2 – Séquence proposée. Les travaux logiciels, le pilote et le test confirmatoire sont des étapes futures ; aucune performance n'est dessinée. Les seuils et la taille finale sont gelés après développement, avant test.

Les décisions confrontent l'estimation et son incertitude aux marges fixées avant le test ; une moyenne favorable ne suffit pas.

Résultat selon critères préfixés	Décision proposée
Gain supérieur au minimum utile, FP/fiabilité/coût acceptables.	Conserver le LLM sur le périmètre établi ; rechercher ensuite le mécanisme.
D1 non inférieur selon marge fixée, moins coûteux et plus fiable.	Utiliser D1 pour les décisions ; évaluer D1-R séparément si nécessaire.
Gain seulement sur les cas ambigus.	Définir un routage règles vers LLM sur développement, puis évaluer le routeur et ses faux refus sur un nouveau test.
Interprétation meilleure hors ligne, pas de gain terrain.	Examiner collecte, contexte, exécution et preuve ; corriger sur développement puis retester.
FP ou fiabilité dégradés au-delà des marges.	Restreindre ou désactiver l'adaptation sur ce périmètre.
Incertitude trop grande ou peu de familles.	Résultat indéterminé ; ajouter diversité ou réduire la portée.

Table 5 – Accepter une conclusion négative fait partie du protocole. Aucune marge numérique n'a encore été choisie.

Il reste à fixer avant le test : gain minimal utile, marges de faux positifs et fiabilité, budgets, règles de données manquantes, taille fixe, exclusions et analyses secondaires. Une absence de significativité ne prouve pas l'équivalence. Si l'utilité se situe dans la construction de règles, une autre expérience peut comparer humain seul et humain assisté pour la maintenance, puis exécuter le workflow déterministe ; ce n'est pas un gain d'agent à chaque audit.

8 Validation disponible et limites de la revue

Vérification	Résultat disponible au 29 septembre 2026
Inventaire statique	29 SHA de vérités terrain concordants ; totaux du corpus vérifiés avec fusion des sidecars.
Composition GT	31 fichiers examinés, dont S1h/S4h ; 13 différences descriptives historiques acceptées et 18 correspondances strictes. Pas de validation strict-all .
Probes synthétiques	Trois probes évaluation et cinq contexte rejouées ; défauts caractérisés, fréquence terrain inconnue.
Tests ciblés	381 cas réussis en 8,35 s dans un venv Python 3.12.2 / pytest 9.1.1 ; fournisseurs et outils simulés.
Manifeste exemple	12 paires prévues, zéro admissible, 24 bras non exécutés ; huit champs configuration non fixés et coûts inconnus. Cela décrit l'exemple uniquement.

Table 6 – Validation logicielle et de définitions, distincte d'une campagne expérimentale.

Les reproductions sont conservées dans `benchmarks/experiments/research-review/` : `inventory.py`, `probe-evaluation.py` et `probe-context.py`. Les versions, commandes, incidents d'environnement résolus et observations sont détaillés dans `research/agent-vs-automation/validation.md`. Les assertions du probe contexte caractérisent les défauts de cette révision ; elles ne sont pas des tests du contrat souhaité après correction.

Les métadonnées historiques examinées ne donnent pas suffisamment de provenance pour en déduire une performance actuelle. Les données test S20–S29 sont publiques et leur indépendance historique reste non vérifiée. Préparer un jeu réservé avec séparation réelle des fichiers et oracles ; le chemin D1/A1 sur inventaire ne bénéficie pas automatiquement de l'isolation scellée.

La revue bibliographique est ciblée et non systématique. Les évaluations CTF et cyber publiées motivent des précautions [6, 7, 8], mais leurs scores ne sont pas comparables au F1 IoT de LANCE. Aucune performance externe n'est reproduite ici. La contrelecture GPT a précisé l'attribution et les critères ; la contre-revue Muse préparée reste non exécutée et aucun avis ne lui est attribué. Les questions et arbitrages figurent dans `adversarial-review.md`.

Références

- [1] S. Kapoor et al. *AI Agents That Matter*. arXiv :2407.01502v1, 1 juillet 2024. Revue initiale : sections 2, 5, 6 et passages d'annexe lus ; tâches programmation/navigation, pas audit IoT. Consulté le 29 septembre 2026. <https://arxiv.org/html/2407.01502v1>.
- [2] ProjectDiscovery. *Template Workflows Overview*. Documentation vivante, version/date de publication non précisées. Workflows conditionnels et contexte partagé lus ; consultation le 29 septembre 2026. <https://docs.projectdiscovery.io/templates/workflows/overview>.
- [3] Anthropic Engineering. *Effective context engineering for AI agents*, 29 septembre 2025. Corps principal, récupération, compaction et notes structurées lus ; recommandation fournisseur, pas expérimentation LANCE. Consulté le 29 septembre 2026. <https://www.anthropic.com/engineering/effective-context-engineering-for-ai-agents>.
- [4] N. F. Liu et al. *Lost in the Middle : How Language Models Use Long Contexts*. arXiv :2307.03172v3, 20 novembre 2023. Résumé et historique lus ; pas article intégral. Modèles/tâches de 2023. Consulté le 29 septembre 2026. <https://arxiv.org/abs/2307.03172v3>.
- [5] R. Dror et al. *The Hitchhiker's Guide to Testing Statistical Significance in Natural Language Processing*. ACL 2018. Notice et sections 3.2–3.3 lues ; principes généraux, pas validation de nos grappes. Consulté le 29 septembre 2026. <https://aclanthology.org/P18-1128/>.
- [6] L. Gioacchini et al. *AutoPenBench : A Vulnerability Testing Benchmark for Generative Agents*. EMNLP Industry, novembre 2025. Sections 2–5 et limitations lues ; assistance humaine et conditions à distinguer. Consulté le 29 septembre 2026. <https://aclanthology.org/2025.emnlp-industry.114.pdf>.
- [7] A. K. Zhang et al. *Cybench*. ICLR 2025. Notice officielle/résumé lus dans la revue comparative ; présentation des auteurs lue dans la revue benchmark. CTF, pas mesure des contrôles sains IoT. Consulté le 29 septembre 2026. <https://cybench.github.io/>.
- [8] Y. Zhu et al. *CVE-Bench*. ICML/PMLR 267, juillet 2025. Notice et résumé lus ; exploitation web critique, pas corpus IoT exhaustif. Consulté le 29 septembre 2026. <https://proceedings.mlr.press/v267/zhu25i.html>.